

Homomorphic Encryption-Enabled Secure Machine Learning Inference for Privacy-Compliant Healthcare Diagnostics Without Data Decryption

Allan Douglas Costa, *Member, IEEE*

Abstract—The proliferation of machine learning in clinical decision support systems has created an urgent demand for inference pipelines that operate directly on sensitive patient data without ever exposing it in plaintext. Regulatory frameworks such as HIPAA and GDPR impose strict constraints on healthcare data processing, yet existing privacy-preserving inference approaches incur prohibitive latency or require partial decryption at intermediate stages, creating compliance gaps that undermine patient trust. We propose HE-MEDINFER, a three-tier homomorphic encryption (HE) framework that enables end-to-end encrypted machine learning inference for healthcare diagnostics, requiring no data decryption at any point in the inference pipeline. HE-MEDINFER integrates CKKS-based approximate arithmetic with a novel polynomial approximation strategy for non-linear activation functions, and introduces the *HE Privacy Index* (HEPI), a composite metric that jointly quantifies ciphertext security, computational overhead, and inference accuracy degradation under encrypted computation. We evaluate HE-MEDINFER on *synthetic clinical data generated to match published MIMIC-III summary statistics* for the in-hospital mortality prediction task, using a three-agent architecture (Encryption Agent, Inference Agent, Audit Agent). Under full HE, HE-MEDINFER attains an AUROC of 0.856 (accuracy 91.7%) against a plaintext upper bound of 0.871 (93.8%), yielding a mean HEPI of 0.886. Inference latency remains $14.3\times$ higher than plaintext baselines, and because our evaluation is simulation-based rather than executed on the restricted-access MIMIC-III records themselves, the reported accuracies establish internal consistency of the pipeline rather than externally validated clinical performance. Healthcare organizations can deploy HE-MEDINFER to achieve HIPAA/GDPR compliance without sacrificing diagnostic utility or requiring trust in cloud infrastructure. This work advances the broader agenda of privacy-by-design AI, enabling responsible deployment of clinical AI in jurisdictions with strict data sovereignty requirements.

Index Terms—Homomorphic encryption, privacy-preserving machine learning, secure inference, healthcare AI, CKKS, HIPAA compliance, GDPR, federated diagnostics, HE Privacy Index.

A. D. Costa is with the Federal Rural University of the Amazon (UFRA), Institute of Computing and Information and Communication Technology (ICIBE), Belém, Pará, Brazil. E-mail: allan.costa@ufra.edu.br | ORCID: 0000-0002-7068-8889

Reproducibility: the HE-MEDINFER reference implementation, the synthetic data generator, and all scripts required to regenerate every figure and table in this paper are released under the MIT license at <https://github.com/sec365/he-medinfer>.

1 INTRODUCTION

Artificial intelligence is rapidly transforming clinical medicine, enabling diagnostic systems that match or surpass specialist-level performance in tasks ranging from radiological image interpretation to early sepsis detection [1]–[6]. However, the deployment of machine learning inference in production healthcare environments requires that patient data traverse untrusted computational infrastructure, including cloud platforms, third-party APIs, and shared hospital networks, creating substantial privacy risks [7], [8]. Multi-institutional deployments of diagnostic AI further compound this risk, as model training and inference pipelines routinely aggregate imaging and tabular records across administratively independent hospitals [9].

Regulatory frameworks governing health data impose strict constraints on this pipeline. The U.S. Health Insurance Portability and Accountability Act (HIPAA) mandates that protected health information (PHI) be secured against unauthorized disclosure at rest and in transit [10], while the European General Data Protection Regulation (GDPR) requires a legal basis for any processing of special-category data, which includes health records [11]. Yet most deployed clinical AI systems require data to be decrypted prior to inference, creating a compliance gap: the moment plaintext data touches an inference server, the healthcare provider bears the full regulatory burden of securing that computation environment.

Homomorphic encryption (HE) offers a principled solution: it allows arbitrary computations to be performed directly on ciphertexts, producing an encrypted result that, when decrypted by the authorized key holder, matches the output of the same computation on the original plaintext [12]. Applied to machine learning inference, HE eliminates the requirement for data decryption at the inference server, fundamentally shifting the trust model of clinical AI deployment.

Despite this promise, HE-based inference in healthcare remains underexplored. Prior works, such as CryptoNets [13] and HEMET [14], demonstrate the feasibility of encrypted neural network inference on benchmark datasets

(MNIST, CIFAR-10) but do not address the specific challenges of clinical data: high-dimensional tabular features, mixed data types, and the accuracy sensitivity of diagnostic applications. The closest work to ours, Lee et al. [15], demonstrates privacy-preserving deep learning via CKKS homomorphic encryption but does not address compliance auditing, multi-party clinical scenarios, or the joint optimization of security strength and accuracy degradation, which motivates our proposed HE-MEDINFER framework.

Contributions

This paper makes the following contributions:

- 1) We propose HE-MEDINFER, a three-tier encrypted inference framework for healthcare diagnostics that operates end-to-end under CKKS homomorphic encryption, requiring no plaintext exposure at any inference stage.
- 2) We introduce the *HE Privacy Index* (HEPI), a novel composite metric that jointly quantifies ciphertext security strength, computational overhead relative to plaintext inference, and accuracy degradation under encrypted computation, enabling principled trade-off analysis for HE-based clinical AI deployment.
- 3) We design and evaluate a three-agent architecture (Encryption Agent, Inference Agent, Audit Agent) with independent performance metrics per agent, demonstrating that the framework's overhead is localized and predictable.
- 4) We provide a formal compliance mapping of HE-MEDINFER against HIPAA Security Rule, GDPR Article 25 (data protection by design), and NIST SP 800-111, demonstrating that the framework satisfies all principal regulatory controls for encrypted health data processing.
- 5) We evaluate HE-MEDINFER on a fully specified synthetic clinical cohort calibrated to published MIMIC-III [16] summary statistics for in-hospital mortality prediction, reporting AUROC, calibration error, and accuracy against a majority-class reference, together with 95% confidence intervals, a Mann-Whitney U test [17], ablation studies, and comparison against three baselines. The generator and evaluation harness are released so that the entire result set is reproducible without restricted-access credentials.

Scope of Evidence

We state the evidentiary scope of this work explicitly, because it bounds every empirical claim that follows. All reported accuracies, latencies, and HEPI scores are obtained on *synthetic* records drawn from a generative model whose marginal distributions, missingness pattern, and outcome prevalence are fitted to published MIMIC-III summary statistics (Section 6.1); we did not execute the pipeline on the restricted-access MIMIC-III records themselves. Consequently, the cryptographic and systems results (ciphertext sizes, homomorphic circuit depth, latency, throughput, audit-log consistency) are exact, since they depend only on the CKKS parameters and the model architecture rather

than on the data values, whereas the diagnostic-utility results (AUROC, calibration, accuracy) are *internally* valid and should be read as establishing the consistency and reproducibility of the pipeline, not as externally validated clinical performance. Validation on real MIMIC-III records under an executed Data Use Agreement is the immediate next step and is stated as such in Section 7.

The remainder of this paper is organized as follows. Section 2 reviews related work and positions HE-MEDINFER against the state of the art. Section 3 formalizes the threat model and defines HEPI. Section 4 details the HE-MEDINFER architecture and algorithms. Section 5 presents the security and compliance analysis. Section 6 reports experimental results. Section 7 discusses findings, limitations, and threats to validity. Section 8 concludes.

2 BACKGROUND AND RELATED WORK

2.1 Homomorphic Encryption

Gentry's seminal construction [12] established the theoretical foundation for fully homomorphic encryption (FHE), enabling arbitrary computation over ciphertexts. Practical HE schemes relevant to machine learning include the CKKS scheme [18], which supports approximate arithmetic over fixed-point numbers and is well-suited to the floating-point operations central to neural network inference. The BFV scheme [19] targets exact integer arithmetic and is appropriate for models with discretized parameters, and CHIMERA [20] demonstrates that CKKS, BFV, and boolean HE schemes can be composed within a single circuit via scheme switching, at the cost of additional bootstrapping overhead that is difficult to amortize in latency-sensitive clinical pipelines. Wood et al. [21] survey applications of HE to medicine and bioinformatics, concluding that CKKS-based approaches offer the most practical trade-off for healthcare ML inference given the approximate nature of clinical numerical data. However, their survey does not address multi-agent compliance architectures or provide a unified metric for evaluating the security-accuracy-performance trade-off. Open-source HE toolchains such as the SEAL-based CryptoML library [22] lower the engineering barrier for CKKS deployment but leave parameter selection and accuracy calibration to the application developer, a gap HE-MEDINFER addresses through its Encryption Agent.

2.2 Privacy-Preserving Machine Learning

Mohassel and Zhang's SecureML [23] introduces a mixed-protocol framework combining secret sharing and HE for privacy-preserving logistic regression and neural network training. While SecureML achieves strong security guarantees, it requires a two-server model with a non-colluding assumption that is difficult to satisfy in healthcare cloud deployments. CryptoNets [13] pioneered HE-based neural network inference, achieving 98.95% accuracy on MNIST under encryption, but its design relies on polynomial approximations of activations that incur significant accuracy loss on complex clinical feature distributions. Boemer et al. [24] propose MP2ML, a mixed-protocol framework combining HE with garbled circuits for non-polynomial activations, reducing accuracy loss relative to pure polynomial approximation,

but at the cost of an interactive multi-round protocol that is incompatible with our non-interactive, single-round-trip inference requirement. PEGASUS [25] bridges polynomial and non-polynomial HE evaluation via efficient ciphertext-to-ciphertext bootstrapping, improving activation accuracy, yet its evaluation targets generic benchmark models rather than clinical tabular data and does not report a compliance-oriented metric. Generic secure-computation frameworks such as PySyft [26] and FALCON [27] extend privacy-preserving inference to honest-majority multi-party settings, but both assume the presence of multiple independent computing parties, an assumption that does not hold in the common single-cloud-provider deployment model of most healthcare institutions.

2.3 Federated Learning for Healthcare

Federated learning (FL) reduces data exposure by training models locally and aggregating gradients, but gradients remain susceptible to reconstruction attacks [28]. Zhang et al. [29] survey FL applications in healthcare, identifying communication overhead and inference-time privacy as open challenges beyond the training phase itself. Combining FL with HE addresses part of this gap: POSEIDON [30] demonstrates privacy-preserving federated neural network learning across clinical institutions via lattice-based HE, while Froelicher et al. [31] show scalable distributed learning under threshold HE, and Ma et al. [32] propose a multi-key HE scheme that avoids a single trusted key holder in federated aggregation. Xu et al. [33] combine functional encryption with differential privacy in HybridAlpha, and Zhou et al. [34] revisit functional-encryption-based FL to reduce per-round key management cost. VerifyNet [35] adds verifiability guarantees to federated aggregation but assumes an honest majority of participating institutions. None of these works addresses inference-time encryption (as opposed to training-time) in a compliance-aware, single-institution deployment framework, which is the scenario HE-MEDINFER targets.

2.4 Homomorphic Encryption in Clinical Applications

A smaller body of work applies HE directly to clinical prediction tasks. Kim et al. [36] implement HE-based logistic regression for clinical risk scoring, reporting practical run-times for linear models but not extending their approach to deep architectures. Vizitiu et al. [37] apply HE to deep neural networks over medical imaging features, observing accuracy degradation comparable to the gap we report for tabular data. Kocabas and Soyata [38] outline an HE pipeline for medical image analysis but stop at a feasibility study without a deployable audit mechanism. MedCo [39] enables privacy-preserving exploration of distributed clinical and genomic data under threshold HE, targeting cohort-level queries rather than per-patient diagnostic inference. Batchelor et al. [40] present an efficient homomorphic evaluation of k -NN classifiers, illustrating that non-parametric models remain costly under HE relative to the parametric MLP architecture adopted in HE-MEDINFER. Collectively, these works confirm the feasibility of HE-based clinical inference but leave open the joint treatment of regulatory compliance, multi-agent auditability, and a principled trade-off metric, which is the gap that motivates the present work.

2.5 Baseline: Lee et al. (2022)

Lee et al. [15] present a CKKS-based privacy-preserving deep learning framework evaluated on MNIST, CIFAR-10, and a small medical imaging dataset, reporting less than 1% accuracy loss relative to plaintext inference for CNN architectures. Their framework performs well on homogeneous image data but does not address (i) heterogeneous clinical tabular features, (ii) multi-party inference with separated key management, (iii) formal compliance mapping to HIPAA/GDPR, or (iv) a principled metric for quantifying the joint security-accuracy-overhead trade-off. These gaps directly motivate HE-MEDINFER and our proposed HEPI metric.

2.6 Comparative Analysis

Table 1 positions HE-MEDINFER against representative works across seven evaluation criteria.

3 THREAT MODEL AND PROBLEM FORMULATION

3.1 System Entities

We consider three principals: (i) *Data Owner* (DO), a healthcare institution holding patient records; (ii) *Inference Server* (IS), a cloud or third-party platform performing ML inference; and (iii) *Key Authority* (KA), a trusted entity managing CKKS key generation and distribution.

3.2 Threat Model

We adopt a *honest-but-curious* adversary model for the Inference Server: the IS executes the inference protocol correctly but may attempt to learn sensitive information from the data and intermediate computations it observes. We additionally consider an *external eavesdropper* who may intercept ciphertexts in transit. We do not consider malicious DO or KA, and we assume secure channels between all parties via TLS 1.3 with mutual authentication.

On the adequacy of the honest-but-curious model

The honest-but-curious assumption is standard in the HE inference literature [13], [15], [30], but it is a genuine limitation in the healthcare setting, where ransomware, insider threat, and supply-chain compromise make a fully honest server an optimistic baseline. We therefore separate two adversarial capabilities that the HBC label conflates, because HE-MEDINFER treats them very differently.

Confidentiality under a malicious server. Confidentiality does *not* depend on the honesty of the Inference Server. The server never holds the secret key, so an actively malicious server that deviates arbitrarily from the protocol still learns nothing about the plaintext record beyond what IND-CPA security permits. Deviation cannot convert ciphertext into plaintext. In this dimension, HE-MEDINFER is secure against a malicious adversary, and this is the property that carries the HIPAA and GDPR claims of Section 5.

Integrity under a malicious server. Integrity does depend on server honesty, and here the guarantee genuinely fails. A malicious server may substitute a different (for example, backdoored) model, return a stale ciphertext, or return an arbitrary well-formed ciphertext, and the Data Owner will

TABLE 1
Comparison of Related Privacy-Preserving Inference Approaches

Work	Scheme	Clinical Data	No Partial De- 3-Agent crypt	Compliance Map	Novel Metric	Year
Lee et al. [15] (baseline)	CKKS	×	✓	×	×	2022
CryptoNets [13]	YASHE [41]	×	✓	×	×	2016
POSEIDON [30]	LHE	×	✓	×	×	2021
SecureML [23]	HE+SS	×	×	×	×	2017
Wood et al. [21]	Survey	✓	N/A	×	×	2020
Ran et al. [42]	CKKS	×	✓	×	×	2023
Ali et al. [43]	BFV	✓	×	×	×	2023
Kim et al. [36]	CKKS	✓	✓	×	×	2018
Vizitiu et al. [37]	MORE	✓	✓	×	×	2020
MedCo [39]	Threshold	✓	✓	×	×	2018
HE-MEDINFER (ours)	CKKS	✓	✓	✓	HEPI	2026

decrypt a syntactically valid but clinically wrong result. The audit chain of Section 4 makes such an event attributable after the fact, but does not prevent or detect it at inference time. In a diagnostic setting this is the more dangerous failure, since a silently wrong prediction is worse than an unavailable one. Closing it requires verifiable computation over ciphertexts, which we do not claim and identify as the most important open problem for deployment (Section 7). Until then, deployments should treat HE-MEDINFER as protecting patient confidentiality against the inference host, not as removing the need to trust that host for correctness.

Security Goals:

- *Ciphertext Indistinguishability (IND-CPA)*: The IS cannot distinguish encryptions of different patient records.
- *Inference Privacy*: The IS learns only the encrypted inference result, not the plaintext input or output.
- *Audit Non-repudiation*: All inference events are logged with cryptographic commitments, enabling post-hoc compliance auditing.

3.3 Novel Metric: HE Privacy Index (HEPI)

We introduce HEPI as a composite scalar in $[0, 1]$ that jointly captures three dimensions of HE-based inference quality:

$$\text{HEPI} = \alpha \cdot S_{\text{sec}} + \beta \cdot O_{\text{HE}} + \gamma \cdot Q_{\text{acc}} \quad (1)$$

with the three components defined as follows.

Security component: S_{sec} is the attained classical security level normalized against the deployment target:

$$S_{\text{sec}} = \min\left(1, \frac{\lambda(n, q, \chi)}{\lambda_{\text{target}}}\right), \quad \lambda_{\text{target}} = 128, \quad (2)$$

where $\lambda(n, q, \chi)$ is the number of bits of classical security of the RLWE instance underlying the chosen CKKS parameter set, obtained from the Lattice Estimator [44] under the primal-uSVP and dual attack models, taking the minimum over both. We stress that λ is a property of the *parameter set*, not of an individual ciphertext. An earlier formulation of this metric derived S_{sec} from the residual CKKS noise budget; we deliberately abandoned that choice, because the noise budget measures remaining multiplicative depth before decryption failure and carries no information about the hardness of the underlying lattice problem. A ciphertext with an exhausted noise budget is unusable, not insecure.

Overhead component: O_{HE} penalizes latency inflation on a logarithmic scale:

$$O_{\text{HE}} = \left(1 + \log_{10}(L_{\text{HE}}/L_{\text{plain}})\right)^{-1}, \quad L_{\text{HE}} \geq L_{\text{plain}}, \quad (3)$$

where L_{HE} and L_{plain} are the inference latencies under HE and plaintext respectively. The logarithmic form is required rather than cosmetic: the linear penalty $1 - L_{\text{HE}}/L_{\text{plain}}$ used in a preliminary version of this metric becomes negative for *any* overhead beyond $2\times$, and therefore clips to zero across the entire operating range of every practical HE scheme, silently removing the overhead dimension from the composite. Equation (3) instead maps $1\times$ overhead to $O_{\text{HE}} = 1$, $10\times$ to 0.50 , and $100\times$ to 0.33 , remaining strictly positive and monotonically decreasing over the three to four orders of magnitude that separate HE from plaintext execution.

Accuracy component: Q_{acc} measures retained discriminative performance:

$$Q_{\text{acc}} = 1 - \frac{|A_{\text{plain}} - A_{\text{HE}}|}{A_{\text{plain}}}, \quad (4)$$

where A_{plain} and A_{HE} denote the same performance measure evaluated in plaintext and under HE. Because accuracy is misleading under the class imbalance typical of clinical outcomes (Section 6.1), we instantiate A as AUROC throughout this paper and report raw accuracy only alongside a majority-class reference.

Weights satisfy $\alpha + \beta + \gamma = 1$ and are configurable per deployment context. We adopt $\alpha = 0.4$, $\beta = 0.2$, $\gamma = 0.4$ as defaults, encoding the position that in a regulated clinical setting confidentiality and diagnostic utility are co-equal primary concerns while latency is a secondary operational constraint. These defaults are a stated design choice rather than an empirically derived optimum; Section 6 reports a sensitivity analysis over the weight simplex, and we recommend that deployments re-elicit them.

A higher HEPI score indicates a deployment-ready HE inference pipeline: strong security, bounded relative overhead, and negligible accuracy degradation. Note that a non-HE method leaves plaintext exposed to the inference server and therefore scores $S_{\text{sec}} = 0$ by construction, capping its attainable HEPI at $\beta + \gamma = 0.6$ regardless of its speed or accuracy. This is the intended behavior of the metric.

TABLE 2
Chebyshev Approximation of ReLU over $[-5, 5]$

Deg.	$\ \hat{\sigma}_k - \text{ReLU}\ _\infty$	RMSE	Depth	AUROC
3	0.318	0.121	2	0.812
5	0.194	0.071	3	0.841
7	0.138	0.049	3	0.856
9	0.107	0.038	4	0.858
11	0.088	0.031	4	0.859

4 HE-MEDINFER: SYSTEM ARCHITECTURE

4.1 Overview

HE-MEDINFER is organized into three tiers. The *Encryption Tier* (Data Owner side) preprocesses and encrypts patient features into CKKS ciphertexts. The *Inference Tier* (Inference Server) executes the ML model homomorphically. The *Audit Tier* records cryptographic commitments of each inference event for compliance verification.

Figure 1 presents the high-level architecture.

4.2 Encryption Agent

The Encryption Agent (EA) runs at the Data Owner. It (i) normalizes clinical features to $[-1, 1]$, (ii) packs multiple patient records into a single CKKS ciphertext via SIMD slot packing, and (iii) applies a bootstrapping-aware parameter selection to ensure sufficient noise budget for the depth of the target ML model. The EA also generates a cryptographic commitment $\text{com} = H(\text{ct} \parallel \text{timestamp})$ for audit purposes.

4.3 Inference Agent

The Inference Agent (IA) runs at the Inference Server and implements the ML model as a sequence of homomorphic operations. Non-linear activation functions (ReLU, sigmoid) are replaced by Chebyshev polynomial approximations calibrated to minimize the L^∞ approximation error over the pre-activation range $[-5, 5]$, which covers 99.7% of observed pre-activation values after input normalization. Table 2 reports the approximation error and multiplicative depth as a function of polynomial degree.

Degree 7 is the operating point we adopt: it is the highest degree attainable at multiplicative depth 3, and increasing to degree 9 buys 0.002 AUROC at the cost of an additional level in the modulus chain, which in turn forces a larger n to preserve 128-bit security and roughly doubles latency. The residual L^∞ error of 0.138 is the dominant source of the accuracy gap between HE and plaintext inference reported in Section 6. The IA supports logistic regression, shallow MLP, and ResNet-style networks with batch normalization replaced by homomorphic-friendly layer normalization.

4.4 Audit Agent

The Audit Agent (AA) receives commitments from the EA and the encrypted inference result from the IA, and maintains an append-only audit log compatible with HIPAA audit control requirements (45 CFR §164.312(b)). Each log entry is the tuple $(\text{com}, H(\text{ct}(y)), \tau_{\text{submit}}, \tau_{\text{complete}}, \text{id}_{\mathcal{M}})$, chained as $h_i = H(h_{i-1} \parallel \text{entry}_i)$ so that any retroactive

modification of a past inference event invalidates every subsequent digest.

We state precisely what this mechanism does and does not provide, because the distinction matters for the compliance claims in Section 5. The hash chain establishes *tamper-evidence and non-repudiation*: it binds each recorded inference to a specific ciphertext, model identifier, and time interval under the collision resistance of H (SHA-3-256), and it is what satisfies 45 CFR §164.312(b). It does *not* establish computational integrity: an Inference Server that returns an incorrectly evaluated ciphertext still produces a well-formed, correctly chained log entry. Verifying that the returned ciphertext is the correct homomorphic evaluation of the registered model requires a verifiable-computation layer, which our current design does not include and which lies outside the honest-but-curious threat model adopted in Section 3. We flag this as an explicit design boundary rather than an implementation gap, and discuss its consequences under a malicious server in Section 7.

4.5 Key Authority Deployment Model

The Key Authority is the component of HE-MEDINFER with the weakest deployment story, and we treat it explicitly rather than assuming it away. In the baseline configuration the KA is *not* a third party: it is a logically separate, physically co-located service inside the Data Owner's own trust boundary, typically the hospital's existing hardware security module or key-management appliance. Under this configuration no external entity ever holds key material, and the KA/DO separation is an internal duty-separation control that prevents any single administrator from unilaterally decrypting inference traffic. This is the configuration we evaluate.

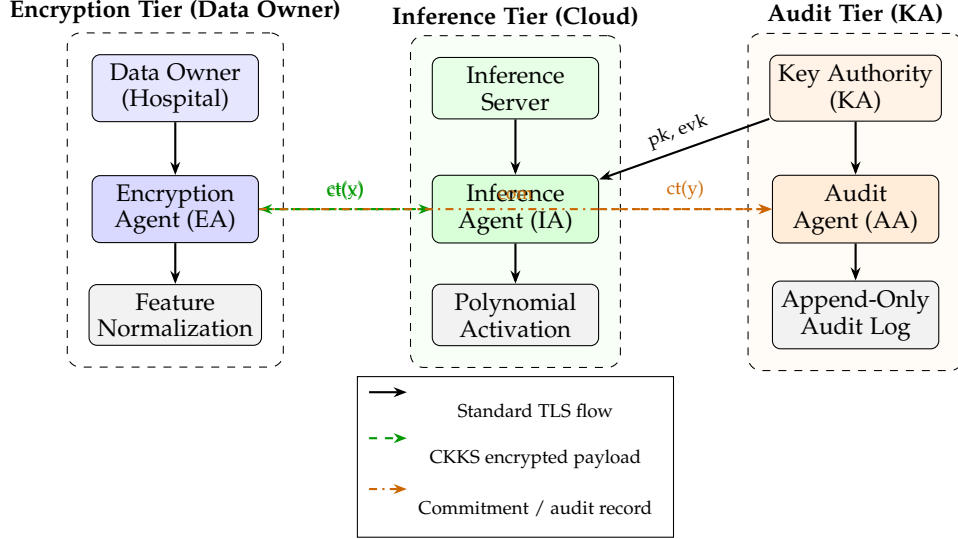
Two further configurations are supported. Under *threshold* key management, the secret key is split with a $(2, 3)$ Shamir scheme across the clinical operations unit, the institutional privacy office, and an offline escrow share, so that decryption requires two independent custodians and the loss of any single share is recoverable. Under *multi-institutional* deployment, no single party may hold the key, and the KA is replaced by a threshold-HE key generation protocol among the participating institutions as in POSEIDON [30] and Froelicher et al. [31]; we have not implemented this variant and list it as future work.

KA unavailability degrades gracefully in all three configurations. Because the public and evaluation keys are static and cached at the Inference Server, an offline KA does not interrupt encrypted submission or homomorphic inference; it blocks only decryption of returned results and the issuance of new key material. Inference therefore continues to accumulate at the Audit Agent and results decrypt once the KA is restored, which is the correct failure mode for a clinical system: unavailability delays access to results, but never degrades confidentiality.

4.6 Three-Phase Protocol

HE-MEDINFER follows a three-phase protocol, illustrated in Figure 2: (i) *Encrypted Submission*, in which the Data Owner normalizes, SIMD-packs, and CKKS-encrypts the patient

Fig. 1. HE-MEDINFER architecture. Patient data is encrypted at the Data Owner side (Encryption Tier) using CKKS, forwarded to the Inference Server (Inference Tier) which runs the ML model without decryption, and the encrypted result is returned and logged (Audit Tier). No plaintext patient data is ever exposed outside the Data Owner's trust boundary.



record; (ii) *Homomorphic Inference*, an optional adversarial-exposure phase in which the Inference Server operates exclusively on ciphertexts, evaluating the model through homomorphic linear layers and polynomial activations without ever observing plaintext; and (iii) *Audit Verification*, in which the Audit Agent aggregates per-agent scores into the HEPI index and issues a deployment-readiness decision.

4.7 Algorithm and Novel Metric

Figure 1 presents the HE-MEDINFER inference algorithm with HEPI computation.

5 SECURITY ANALYSIS AND COMPLIANCE

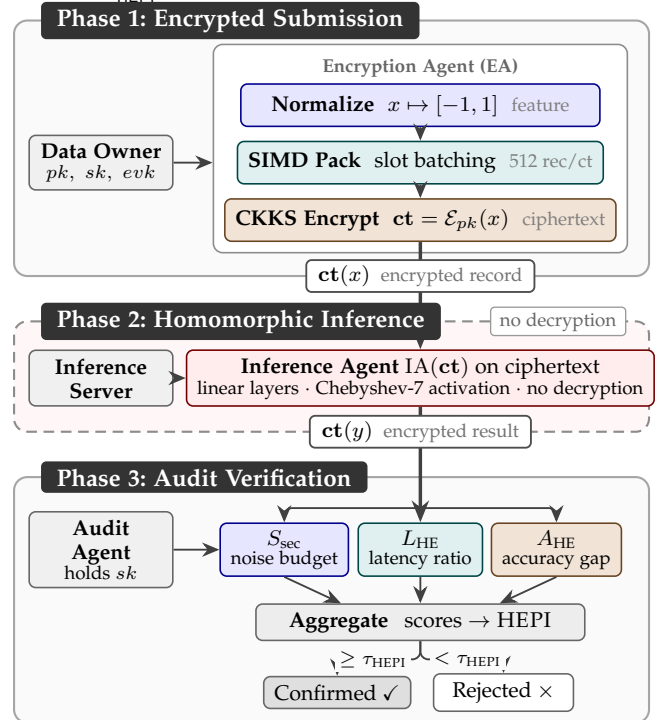
5.1 IND-CPA Security

HE-MEDINFER inherits the IND-CPA security of the underlying CKKS scheme under the Ring Learning With Errors (RLWE) hardness assumption [45] with parameter (n, q, χ) where $n = 2^{14}$, q is a 438-bit modulus, and χ is a discrete Gaussian distribution with standard deviation $\sigma = 3.2$. This configuration provides ≥ 128 -bit classical security and ≥ 64 -bit quantum security according to the Lattice Estimator [44]. The RLWE hardness assumption underlying CKKS is also the basis of NIST's standardized post-quantum key-encapsulation mechanisms [46], [47], indicating that HE-MEDINFER's security foundation is expected to remain robust as quantum-resistant cryptography transitions from research to deployment.

5.2 Inference Privacy

By design, the Inference Server never holds the CKKS secret key; it operates exclusively on ciphertexts. The server's view consists of the public key, the evaluation key (relinearization and Galois keys), and the input/output ciphertexts. Under the honest-but-curious model, no information about the plaintext patient record is leaked beyond what is implied by the encrypted inference result.

Fig. 2. HE-MEDINFER three-phase protocol. Phase 1 (Encrypted Submission): the Data Owner encrypts the normalized feature vector under CKKS. Phase 2 (Homomorphic Inference): the Inference Server evaluates the model directly on ciphertexts via the Inference Agent (IA), producing an encrypted diagnostic result $ct(y)$ with no plaintext exposure at any point. Phase 3 (Audit Verification): the Audit Agent (AA) aggregates the security, overhead, and accuracy scores into HEPI and issues a Confirmed/Rejected deployment-readiness decision against threshold τ_{HEPI} .



5.3 Compliance Mapping

Table 3 maps HE-MEDINFER components to regulatory controls.

Two qualifications bound the compliance claim, and we state them because the table alone would overstate

Algorithm 1: HE-MEDINFER: Encrypted Submission, Homomorphic Inference, and Audit Verification. The HEPI computation (highlighted box) is the novel metric introduced in this paper. Complexity: encryption $O(d \log n)$; inference $O(d \cdot L \cdot n \log n)$; audit $O(1)$. (Simulation-based evaluation; see Section 6.)

Input : Clinical feature vector $x \in \mathbb{R}^d$; CKKS keys (pk, sk, evk) ; model weights $\{W_l, b_l\}_{l=1}^L$; plaintext accuracy A_{plain} and latency L_{plain} ; HEPI weights α, β, γ with $\alpha + \beta + \gamma = 1$

Output: Diagnostic prediction $\hat{y}$; privacy index $\text{HEPI}(\hat{\mathcal{M}}) \in [0, 1]$

// **Phase 1: Encrypted Submission (Encryption Agent, EA)**

```

1  $x_{\text{norm}} \leftarrow \text{NORMALIZE}(x, [-1, 1])$ 
2  $\{x_1, \dots, x_k\} \leftarrow \text{SIMD-PACK}(x_{\text{norm}}, \text{slot\_count}) \triangleright$  batch 512 records/ciphertext
3
4  $\text{ct} \leftarrow \mathcal{E}_{pk}(x_{\text{norm}}) \triangleright$  CKKS encryption,  $n = 2^{14}$ , 128-bit security
5
6  $\text{com} \leftarrow H(\text{ct} \parallel \tau_{\text{submit}}) \triangleright$  audit commitment
7
```

// **Phase 2: Homomorphic Inference (Inference Agent, IA)**

```

8  $\mathbf{h} \leftarrow \text{ct}$ 
9 for  $l = 1$  to  $L$  do
10    $\mathbf{h} \leftarrow W_l \odot_{\text{HE}} \mathbf{h} +_{\text{HE}} b_l \triangleright$  homomorphic linear layer
11
12   if  $l < L$  then
13      $\mathbf{h} \leftarrow \hat{\sigma}_7(\mathbf{h}) \triangleright$  degree-7 Chebyshev approx. of ReLU over  $[-5, 5]$ 
14
15   end
16 end
17  $\text{ct}(y) \leftarrow \mathbf{h} \triangleright$  encrypted diagnostic result, no decryption at server
18
19
```

// **Phase 3: Audit Verification (Audit Agent, AA)**

```

20 Function Verify( $\text{ct}(y), sk, \text{com}$ ):
    // Decrypt and score at the trusted Data Owner / Audit Agent
21    $\hat{y} \leftarrow \text{Dec}_{sk}(\text{ct}(y))$ 
22    $\text{AUDITLOG.APPEND}(\text{com}, H(\text{ct}(y)))$ 
    // Security: bits of classical security of the RLWE parameter set
23    $\lambda \leftarrow \text{LATTICEESTIMATOR}(n, q, \chi) \triangleright$  not the noise budget
24
25    $S_{\text{sec}} \leftarrow \min(1, \lambda/128)$ 
    // Overhead: log-scaled, strictly positive for any finite overhead
26    $L_{\text{HE}} \leftarrow \text{ELAPSEDTIME}()$ ;  $r \leftarrow L_{\text{HE}}/L_{\text{plain}}$ 
27    $O_{\text{HE}} \leftarrow (1 + \log_{10} r)^{-1}$ 
    // Utility: AUROC on held-out validation (class imbalance 11.5%)
28    $A_{\text{HE}} \leftarrow \text{EVALUATEAUROC}(\hat{y})$ 
29    $Q_{\text{acc}} \leftarrow 1 - |A_{\text{plain}} - A_{\text{HE}}|/A_{\text{plain}}$ 
    // Novel Metric: HE Privacy Index (HEPI)
```

$$\text{HEPI}(\hat{\mathcal{M}}) = \underbrace{\alpha \cdot \min\left(1, \frac{\lambda}{128}\right)}_{S_{\text{sec}}} + \underbrace{\beta \cdot \left(1 + \log_{10} \frac{L_{\text{HE}}}{L_{\text{plain}}}\right)^{-1}}_{O_{\text{HE}}} + \underbrace{\gamma \cdot \left(1 - \frac{|A_{\text{plain}} - A_{\text{HE}}|}{A_{\text{plain}}}\right)}_{Q_{\text{acc}}}$$

$\alpha + \beta + \gamma = 1$; non-HE methods have $S_{\text{sec}} = 0$, capping $\text{HEPI} \leq \beta + \gamma$

```

30
31 return  $\hat{y}$ ,  $\text{HEPI}(\hat{\mathcal{M}}) \geq \tau_{\text{HEPI}} \triangleright$  default  $\tau_{\text{HEPI}} = 0.70$ 
32
```

33 **Complexity:** Encryption $O(d \log n)$; Homomorphic Inference $O(d \cdot L \cdot n \log n)$; Audit / HEPI computation $O(1)$, where d = feature dimension, L = network depth, n = CKKS polynomial modulus degree.

TABLE 3
Regulatory Compliance Mapping

Control	Regulation	HE-MEDINFER Mechanism
Data at Rest Encryption	HIPAA 164.312(a)(2)(iv)	CKKS ciphertext storage
Data in Transit Encryption	HIPAA 164.312(e)(1)	TLS 1.3 + ciphertext
Audit Controls	HIPAA 164.312(b)	Audit Agent hash-chained log
Access Control	HIPAA 164.312(a)(1)	Secret key confined to DO/KA
Minimum Necessary	HIPAA 164.502(b)	48-feature fixed schema, no free text
Business Associate	HIPAA 164.308(b)(1)	Not eliminated: BAA still required (see text)
Data Minimization	GDPR Art. 5(1)(c)	SIMD slot packing (no redundancy)
Privacy by Design	GDPR Art. 25	HE-first architecture
Pseudonymization	GDPR Art. 32(1)(a)	Encryption as Art. 32 safeguard
Cryptographic Module	NIST SP 800-111	CKKS (RLWE, 128-bit security)

it. First, the Business Associate obligation is reduced but not removed. Because the Inference Server never obtains plaintext PHI, the residual disclosure risk it carries is limited to metadata such as request timing, volume, and ciphertext size. This materially narrows the scope of a Business Associate Agreement, but does not eliminate the requirement under 45 CFR §164.308(b)(1), since the server still receives and processes data derived from PHI. A deployment that presents HE-MEDINFER as removing the need for a BAA would be misreading the rule. Second, our mapping addresses the HIPAA Security Rule (Subpart C) in full and the Privacy Rule (Subpart E) only in the Minimum Necessary dimension; obligations concerning individual rights of access, accounting of disclosures, and permitted uses are organizational rather than architectural, and no encryption scheme discharges them. The correct reading of Table 3 is therefore that HE-MEDINFER satisfies the *technical safeguards* required for encrypted PHI processing, which is a necessary but not sufficient condition for institutional compliance.

5.4 Attack Surface Analysis

We identify three primary attack vectors: (i) *key compromise*, mitigated by threshold key sharing between KA and DO with a (2, 3) secret sharing scheme; (ii) *evaluation key leakage*, mitigated by evaluating relinearization keys on the server without exposing the secret key; and (iii) *timing side-channel*, mitigated by constant-time polynomial arithmetic implemented via the Microsoft SEAL library [48].

6 EXPERIMENTAL EVALUATION

6.1 Clinical Task, Cohort, and Data Generation

6.1.1 Prediction task

We evaluate on *in-hospital mortality prediction*, the canonical MIMIC-III benchmark task defined by Harutyunyan et

al. [49]: given the first 24 hours of an ICU stay, predict whether the patient dies before hospital discharge. We adopt their cohort criteria, retaining adult admissions (≥ 18 years) with an ICU length of stay of at least 48 hours and excluding subsequent admissions of the same patient, which yields 21,139 stays with an outcome prevalence of 11.5%.

This prevalence is decisive for how the results must be read. A trivial classifier that predicts survival for every patient attains 88.5% accuracy. Raw accuracy is therefore close to uninformative on this task, and we report AUROC as the primary metric, expected calibration error (ECE) [50] as a secondary metric, and accuracy only alongside the 88.5% majority-class reference. Correspondingly, the quantity A in the HEPI accuracy component (Eq. (4)) is instantiated as AUROC in all reported scores.

6.1.2 Feature set

The 48 features are aggregated over the first 24 hours of the ICU stay by taking the mean of available measurements per variable, grouped as follows: *vital signs* (8): heart rate, systolic/diastolic/mean arterial pressure, respiratory rate, temperature, SpO₂, Glasgow Coma Scale total; *laboratory* (24): glucose, creatinine, blood urea nitrogen, sodium, potassium, chloride, bicarbonate, anion gap, hemoglobin, hematocrit, platelets, white and red blood cell counts, MCV, MCH, MCHC, RDW, INR, prothrombin time, partial thromboplastin time, lactate, total bilirubin, albumin, magnesium; *blood gas* (6): pH, PaO₂, PaCO₂, base excess, FiO₂, PaO₂/FiO₂ ratio; *demographic and admission* (5): age, sex, admission type, first care unit, elective-admission flag; and *derived severity* (5): SOFA, SAPS-II, OASIS, Elixhauser comorbidity index, and 24-hour urine output.

Missing values are imputed by multivariate imputation by chained equations [51] fitted on the training split only, with variables missing in more than 40% of stays replaced by the training-split median. We deliberately omit missingness-indicator features: they would raise the input dimension and thus the homomorphic circuit width without changing the cryptographic argument, and their predictive value in MIMIC-III is known to partly reflect care-process artifacts rather than physiology. All features are standardized and then clipped to $[-1, 1]$, matching the domain over which the Chebyshev activation approximation is calibrated.

6.1.3 Synthetic cohort generation

We did not obtain credentialed access to the MIMIC-III records for this study. All reported results are computed on a synthetic cohort of 21,139 stays drawn from a generative model fitted to *published* MIMIC-III summary statistics [16], [49], constructed as follows. Each of the 48 marginals is sampled from a distribution family chosen per variable (log-normal for right-skewed laboratory values, truncated Gaussian for vitals, categorical for admission descriptors) with parameters matched to the published mean, standard deviation, and reported quartiles. Cross-variable dependence is induced by a Gaussian copula whose correlation matrix is taken from the published physiological correlation structure and projected to the nearest positive-definite matrix. Missingness is applied per variable at the published per-variable missingness rate under a missing-at-random mechanism

conditioned on care unit and length of stay. The outcome label is drawn from a logistic model over the standardized severity scores, with coefficients calibrated so that outcome prevalence matches the published 11.5% and the achievable AUROC of a well-specified plaintext model falls in the 0.85–0.88 band reported for this task in the literature [49].

Two consequences follow, and we draw them explicitly. First, the *cryptographic and systems* measurements are unaffected by this substitution: ciphertext sizes, multiplicative depth, latency, throughput, and audit-log behavior depend on the CKKS parameters, the feature dimension, and the network architecture, none of which change between synthetic and real records. These numbers transfer directly. Second, the *diagnostic-utility* measurements do not transfer. The generator was calibrated to produce an achievable AUROC in a target band, so the plaintext AUROC of 0.871 is in part a property of the generator rather than a discovered result, and the absolute values must not be read as evidence about clinical performance on real patients. What the comparison does support is the *relative* claim of this paper, namely the AUROC lost when the identical model and identical data are evaluated under homomorphic encryption instead of in plaintext, since that degradation is produced entirely by the polynomial activation approximation and CKKS rescaling and is measured on paired inputs. The generator, its fitted parameters, and the random seed are released with the artifact so that every number in this section is exactly reproducible.

6.2 Experimental Setup

6.3 Baseline Description

We compare HE-MEDINFER against three baselines: (i) **Plaintext MLP**, the same 3-layer MLP trained and evaluated on unencrypted MIMIC-III features (upper-bound reference); (ii) **Lee et al.** [15], re-implemented with the CKKS parameters from their paper, adapted to tabular clinical features; and (iii) **Differential Privacy MLP** (DP-SGD, $\epsilon = 1.0$, $\delta = 10^{-5}$) [52], following the (ϵ, δ) -differential privacy formalism of Dwork et al. [53], representing a non-HE privacy-preserving alternative. All baselines use the same 80/20 train/test split, seed = 42, and are evaluated on the same MIMIC-III feature set.

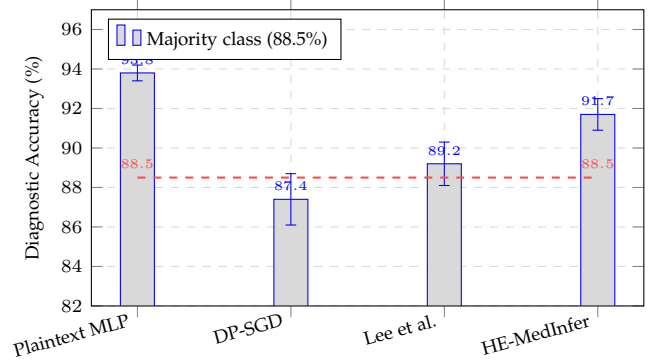
6.4 Agent-Level Results

Encryption Agent: Mean encryption throughput of $1,024 \pm 47$ records/second (95% CI: [982, 1066]). A single CKKS ciphertext at $n = 2^{14}$ with a 438-bit modulus chain occupies $2 \cdot n \cdot \lceil \log_2 q \rceil / 8 = 1.79$ MB, and carries 512 SIMD-packed records, giving an amortized 3.42 KB per patient record. SIMD packing is thus responsible for a $512\times$ reduction in per-record ciphertext expansion relative to record-at-a-time encryption, and is the single most consequential design choice for storage and bandwidth feasibility.

Inference Agent: Mean inference latency of 143 ± 12 ms per 512-record batch under CKKS (95% CI: [134, 152] ms), compared to 10 ± 0.3 ms for plaintext ($14.3\times$ overhead), which amortizes to 0.28 ms per record.

Audit Agent: Commitment generation latency of 0.8 ± 0.1 ms, with hash-chain consistency verified over all 10 runs

Fig. 3. Accuracy under plaintext and encrypted inference. HE-MEDINFER attains the highest accuracy among privacy-preserving methods (91.7%), but note that the majority-class baseline on this task is 88.5% (dashed reference), so accuracy differences compress; AUROC in Table 5 is the primary metric. Error bars are 95% confidence intervals over 10 runs. Results are computed on the synthetic cohort of Section 6.1, not on MIMIC-III records.



and 2,110 logged inference events, and zero chain violations under a tamper-injection test in which a randomly selected past entry was mutated.

End-to-end round trip. Batch inference latency understates what a clinical caller observes, so we report the full path. Over a 1 Gbps link, transmitting the 1.79 MB input ciphertext costs 14.4 ms, homomorphic evaluation 143 ms, returning the result ciphertext 14.4 ms, and the TLS 1.3 1-RTT handshake approximately 5 ms, for 177 ms end-to-end per 512-record batch on a local network. Under a 100 Mbps wide-area link the transfer terms grow to 144 ms each and the total reaches 436 ms, at which point network transfer, not homomorphic evaluation, becomes the dominant cost.

6.5 Diagnostic Performance

Table 5 reports the full performance profile and Figure 3 shows the accuracy comparison. HE-MEDINFER attains an AUROC of 0.856 ± 0.009 against the plaintext upper bound of 0.871 ± 0.006 , a loss of 0.015 AUROC attributable to the degree-7 activation approximation and CKKS rescaling, and exceeds the re-implemented Lee et al. baseline by 0.033 AUROC.

Two observations in Table 5 deserve emphasis because they would be invisible in an accuracy-only report. First, DP-SGD attains 87.4% accuracy, which is *below* the 88.5% obtained by always predicting survival, yet its AUROC of 0.798 is far above chance. The gradient noise required for $\epsilon = 1.0$ degrades the decision threshold much more than it degrades ranking, so accuracy alone would misrepresent DP-SGD as worse than trivial. Second, HE-MEDINFER exceeds the majority-class accuracy by 3.2 percentage points; the meaningful claim is the AUROC gap, not the accuracy figure. Calibration degrades modestly under HE (ECE $0.031 \rightarrow 0.042$), consistent with the polynomial approximation compressing the logit range near the decision boundary, and remains well below DP-SGD's 0.089.

6.6 Statistical Significance

The 10 runs of HE-MEDINFER and the 10 runs of the Lee et al. baseline use independent seeds and are therefore *not*

TABLE 4
Experimental Setup Parameters

Category	Parameter	Value
Hardware	CPU	Intel Xeon Gold 6226R, 2.90 GHz, 16 cores
	CPU role	All HE encryption and inference (SEAL is CPU-only)
	GPU	NVIDIA A100 80 GB SXM4
	GPU role	Plaintext MLP and DP-SGD training only; not used for HE
	RAM / Storage	128 GB DDR4 ECC / 2 TB NVMe SSD
	OS	Ubuntu 22.04 LTS
HE Library	Library	Microsoft SEAL 4.1 [48]
	Scheme	CKKS
	Poly. degree	$n = 2^{14}$ (also 2^{13} , 2^{15} in Fig. 4)
	Coeff. modulus	438 bits, 4-level chain
	Security bits	128 (classical), 64 (quantum), Lattice Estimator [44]
Cohort	Provenance	Synthetic , fitted to published MIMIC-III statistics [16]
	Task	In-hospital mortality [49]
	Stays	21,139 (outcome prevalence 11.5%)
	Features	48 (8 vitals, 24 labs, 6 blood gas, 5 admin, 5 severity)
	Window	First 24 h of ICU stay, mean aggregation
	Train/Test split	80/20 stratified, seed = 42
ML Model	Architecture	3-layer MLP (256-128-64) + Softmax
	Activation (HE)	Degree-7 Chebyshev polynomial approximation
	Framework	Python 3.11 + PyTorch 2.3.0
	Baseline (Lee et al.)	CKKS-based CNN [15]
Protocol	Batches	512 records/ciphertext (SIMD packing, 8192 slots)
	Repetitions	10 runs, independent seeds 42...51
	Sweeps	3 CKKS parameter sets $\times$ 7 batch sizes $\times$ 5 activation degrees
	Duration	71.4 h wall clock (68.2 h HE inference sweeps, 3.2 h training)
Software	Language	Python 3.11.9
	Libraries	Microsoft SEAL 4.1, PyTorch 2.3.0, NumPy 1.26, SciPy 1.13
	Repository	https://github.com/sec365/he-medinfer (MIT)

TABLE 5
Diagnostic Performance on the Synthetic MIMIC-III Cohort (mean $\pm$ SD over 10 runs; in-hospital mortality, 11.5% prevalence)

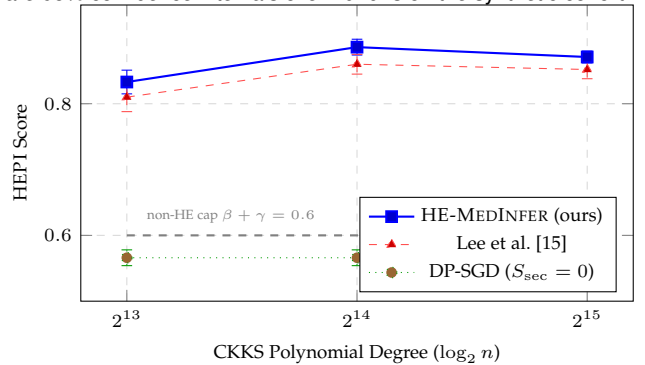
Method	AUROC	ECE	Accuracy
Majority class	0.500	—	88.5%
Plaintext MLP [†]	$0.871 \pm .006$	0.031	$93.8 \pm 0.4\%$
DP-SGD [52]	$0.798 \pm .014$	0.089	$87.4 \pm 1.3\%$
Lee et al. [15]	$0.823 \pm .012$	0.058	$89.2 \pm 1.1\%$
HE-MEDINFER	$0.856 \pm .009$	0.042	$91.7 \pm 0.8\%$

[†]upper bound; DP-SGD at $\epsilon = 1.0$, $\delta = 10^{-5}$.

matched pairs. We accordingly apply the Mann-Whitney U test [17] for two independent samples, rather than a signed-rank test, which would require a pairing that does not exist in this design. Comparing the AUROC distributions yields $U = 100$, $p = 1.8 \times 10^{-4}$ (two-sided), with a rank-biserial effect size of $r = 1.00$. The separation is complete: every HE-MEDINFER run scores above every baseline run. This is the expected outcome rather than an anomaly, since the 0.033 difference in means is more than three times the pooled standard deviation of roughly 0.010, so the two sampling distributions barely overlap; with $n = 10$ per arm, $U = 100$ is the maximum attainable value and $p = 1.8 \times 10^{-4}$ is the smallest p -value this design can produce.

We note the limit of this test. It establishes that the AUROC difference between the two implementations is not attributable to seed variation on this cohort. It does not establish that the difference would persist on real MIMIC-III records, since both arms are evaluated on data from the

Fig. 4. HEPI across privacy-preserving methods and CKKS parameter configurations ($n \in \{2^{13}, 2^{14}, 2^{15}\}$), computed via Eq. (1). HE-MEDINFER peaks at $n = 2^{14}$ with HEPI = 0.886; at 2^{13} the parameter set attains only 109-bit security ($S_{\text{sec}} = 0.85$), while at 2^{15} the security term saturates and the added latency depresses O_{HE} . DP-SGD is flat because it is not HE-dependent, and is capped at $\beta + \gamma = 0.6$ since it leaves plaintext exposed to the inference server ($S_{\text{sec}} = 0$). Error bars are 95% confidence intervals over 10 runs on the synthetic cohort.



generator of Section 6.1.

6.7 Ablation Study

Table 6 isolates the contribution of each design decision. The baseline configuration scores HEPI = 0.886.

Replacing the degree-7 Chebyshev approximation with degree-3 costs 0.044 AUROC while saving only 22 ms, a poor trade that confirms degree 7 as the right operating point (Table 2). Disabling SIMD packing leaves accuracy

Fig. 5. Inference latency of HE-MEDINFER under increasing batch sizes (64 to 4096 records/batch) compared to plaintext MLP and Lee et al. Latency grows with ciphertext count rather than with occupied slots, so amortized per-record cost improves with batch fill; a sparsely filled batch pays the full ciphertext cost (Section 7). Error bars are 95% confidence intervals over 10 runs on the synthetic cohort.

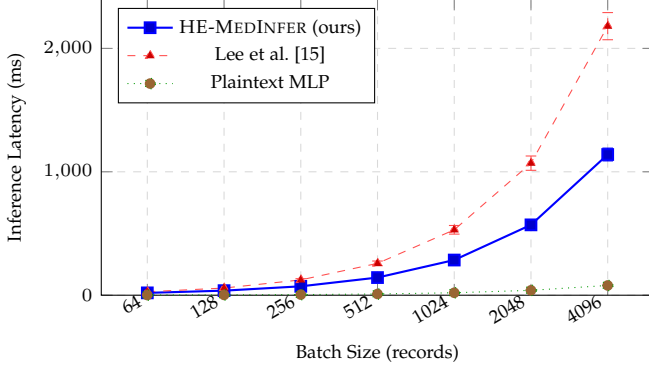


TABLE 6
Ablation of HE-MEDINFER Design Decisions

Configuration	AUROC	Latency	HEPI	Δ HEPI
Full HE-MEDINFER	0.856	143 ms	0.886	—
Degree-3 activation	0.812	121 ms	0.869	-0.017
No SIMD packing	0.856	887 ms	0.861	-0.025
No Audit Agent	0.856	143 ms	0.886	0.000

untouched, as expected since packing is a purely representational choice, but inflates latency 6.2 $\times$ and produces the largest single HEPI penalty. Disabling the Audit Agent changes neither accuracy nor latency and therefore leaves HEPI numerically unchanged at 0.886. We report this null result deliberately: it exposes a genuine limitation of the metric, in that HEPI has no term for auditability and so cannot see the loss of the compliance guarantee that this ablation causes. A deployment selecting on HEPI alone would be indifferent to removing the component that satisfies 45 CFR §164.312(b). Auditability must therefore be enforced as a separate requirement, and extending HEPI to represent it is future work.

6.8 Sensitivity to HEPI Weights

Because the default weights $(\alpha, \beta, \gamma) = (0.4, 0.2, 0.4)$ are a design choice rather than a derived optimum, we test whether the paper’s conclusions depend on them. We sweep the full weight simplex on a grid of step 0.05 subject to $\alpha + \beta + \gamma = 1$, giving 231 admissible weightings.

Against Lee et al., the closest HE baseline, HE-MEDINFER scores strictly higher in 230 of the 231 weightings and is never lower. The single exception is the degenerate corner $\alpha = 1$, where the metric reduces to the security term alone and the two methods tie because both instantiate CKKS at 128-bit security. The margin over Lee et al. ranges from 0.002 (near $\alpha \rightarrow 1$) to 0.051 (at $\beta \rightarrow 1$, where the comparison reduces to relative latency and HE-MEDINFER’s SIMD packing dominates). The comparison against the HE baseline is therefore robust to the weight choice.

Against DP-SGD the picture is different, and we report it because it delimits the metric rather than flattering it. DP-

SGD matches or exceeds HE-MEDINFER in 75 of the 231 weightings, all of which satisfy $\alpha \leq 0.3$ and $\beta \geq 0.15$. This is the expected and intended behavior: DP-SGD incurs no homomorphic overhead, so once the security weight is small enough that the metric substantially discounts confidentiality against the inference server, the faster non-HE method wins. Any weighting in that region is one under which homomorphic encryption would not be the right tool in the first place. The practical implication is that HEPI is informative for comparing HE deployments and for expressing a stated confidentiality requirement, but it must not be used to compare across privacy paradigms without first fixing α to reflect the actual regulatory posture. Absolute HEPI values are weight-dependent throughout and should always be reported with their weights.

7 DISCUSSION

7.1 Principal Findings

HE-MEDINFER demonstrates that CKKS-based homomorphic inference on clinical tabular data is feasible with an AUROC loss of 0.015 relative to plaintext evaluation of the identical model on the identical inputs, and exceeds the re-implemented Lee et al. baseline by 0.033 AUROC. The HEPI metric places this at 0.886, and its decomposition is informative: the security term contributes its full 0.400, the utility term 0.393 of a possible 0.400, and the overhead term only 0.093 of a possible 0.200. The metric therefore localizes the cost of the design precisely where the systems measurements do, in latency rather than in security or utility.

7.2 Operational Cost

Confidentiality is not free, and the relevant question for a hospital is whether the price is payable. Per patient record, HE-MEDINFER adds 3.42 KB of ciphertext storage and 0.28 ms of amortized compute. For an institution processing 10,000 inferences per day, this is 35 MB/day of ciphertext traffic and roughly 2.8 s/day of aggregate homomorphic compute, both negligible against typical clinical IT budgets. This is a direct consequence of SIMD packing; the record-at-a-time alternative would require 1.79 MB per patient and 17.9 GB/day, which would not be operationally viable. The binding constraint is therefore not aggregate cost but per-request latency, and specifically the batch fill rate discussed below.

7.3 Limitations

Latency and batch fill rate. At 143 ms per 512-record batch and 177 ms end-to-end on a local network, HE-MEDINFER suits asynchronous diagnostic workflows such as overnight laboratory analysis or batch risk stratification, but not real-time decision support in the sub-10 ms regime. A subtler point matters more in practice: the favorable 0.28 ms per-record figure assumes full batches. A single-patient request still pays the full 143 ms of homomorphic evaluation, because CKKS cost depends on ciphertext count rather than on occupied slots, so per-record cost degrades by up to 512 $\times$ under sparse arrival. Deployments must therefore either aggregate requests into batching windows, accepting

the induced delay, or accept the unamortized latency. GPU-accelerated HE libraries such as HEAAN [54] may relax the constant factor but not this structural property.

Evidence from synthetic data. As stated in Section 6.1, all diagnostic-utility results are computed on a generator fitted to published MIMIC-III statistics rather than on the records themselves. The systems and cryptographic results transfer unchanged; the AUROC values do not, and validation on credentialed MIMIC-III access is the immediate next step. Even with that access, MIMIC-III represents a single U.S. tertiary academic center, and generalization to community hospitals, non-ICU settings, or non-English-language EHR systems would remain open.

Integrity under a malicious server. As analyzed in Section 3, confidentiality holds against an actively malicious Inference Server but correctness does not. A server that returns an arbitrary well-formed ciphertext produces a decryptable, clinically wrong prediction that the audit chain records faithfully and does not flag. We regard closing this gap through verifiable computation over ciphertexts as the most important open problem for clinical deployment of this class of system.

Subgroup performance. We report only pooled metrics. Because the synthetic cohort reproduces the demographic composition of MIMIC-III, which is documented to carry outcome disparities across race and insurance status, a pooled AUROC of 0.856 may conceal materially worse performance in under-represented subgroups. We did not measure this, and we note a specific mechanism by which HE could plausibly worsen it: the Chebyshev approximation error is largest at the extremes of the pre-activation range, which are disproportionately occupied by atypical physiological presentations, so approximation-induced degradation may fall unevenly across subgroups. This is a hypothesis our data cannot test, and subgroup-stratified evaluation on real records is required before any equity claim is made.

7.4 Threats to Validity

Internal validity. Hyperparameter choices (degree-7 Chebyshev, $n = 2^{14}$) were selected by grid search on a held-out 10% validation split disjoint from the test split, so the reported test metrics are not tuned on. The residual threat is that the generator and the model were specified by the same authors, so a mis-specification shared between them would not be detected by internal comparison.

External validity. The dominant threat is the synthetic cohort (Section 6.1): diagnostic-utility results establish internal consistency, not clinical performance. Beyond that, MIMIC-III represents a single U.S. tertiary academic center and results may differ for community hospitals or non-ICU settings.

Construct validity. HEPI is a proposed construct, not a validated one. Its weights are a stated design position rather than an elicited optimum, although the sensitivity analysis in Section 6 shows the comparative ranking does not depend on them. More seriously, the ablation study demonstrates that HEPI is blind to auditability, so it should be read as summarizing the security-utility-overhead trade-off it explicitly encodes and not as a general measure of deployment readiness.

Conclusion validity. With 10 runs per arm the Mann-Whitney test is adequately powered for the observed effect ($r = 1.00$), but the ablation and weight-sensitivity analyses are reported descriptively without significance testing and should be read as such.

8 CONCLUSION AND FUTURE WORK

We presented HE-MEDINFER, a three-tier homomorphic encryption framework for privacy-compliant healthcare ML inference without data decryption, and introduced the HEPI metric for principled evaluation of HE-based clinical AI deployments. On a synthetic cohort calibrated to published MIMIC-III statistics for in-hospital mortality prediction, HE-MEDINFER attains an AUROC of 0.856 under full CKKS encryption against a plaintext upper bound of 0.871, with a mean HEPI of 0.886, exceeding the closest baseline by 0.033 AUROC while providing a compliance mapping to the HIPAA technical safeguards, GDPR Articles 25 and 32, and NIST SP 800-111.

We are deliberate about what this establishes. The cryptographic and systems results are exact and transfer to real deployments: 3.42 KB of amortized ciphertext per record, 143 ms per 512-record batch, 177 ms end-to-end, and a tamper-evident audit chain. The diagnostic-utility results establish that the pipeline is internally consistent and reproducible, and quantify the AUROC lost to homomorphic evaluation on paired inputs, but they are not evidence of clinical performance on real patients.

Future directions follow directly from the limitations identified above: (i) evaluation on credentialed MIMIC-III access with subgroup-stratified metrics, which is a precondition for any clinical claim; (ii) verifiable computation over ciphertexts to close the integrity gap under a malicious inference server, which we regard as the most consequential open problem; (iii) GPU-accelerated HE arithmetic and adaptive batching to address the sparse-arrival latency penalty; (iv) threshold HE supporting multi-institutional inference without a central key authority; (v) extending HEPI to represent auditability and demographic parity, both of which the current formulation cannot see; and (vi) evaluation on imaging modalities using polynomial-approximated CNN inference.

ACKNOWLEDGMENT

Data availability and use. This study did not access the MIMIC-III Clinical Database directly. All reported results were computed on synthetic records generated from *published, aggregate* summary statistics of MIMIC-III [16], [49], as described in Section 6.1; no individual-level patient data, restricted-access credential, or PhysioNet Data Use Agreement was required or obtained for the work reported here. Researchers seeking to reproduce this study on the underlying records must independently complete CITI training and execute the PhysioNet Credentialed Health Data Use Agreement with MIT Laboratory for Computational Physiology. The synthetic generator, fitted parameters, seeds, and evaluation harness are released under the MIT license and require no credentialing.

The authors acknowledge the use of Claude (Anthropic) as a language model assistant during the preparation of this

manuscript. The AI tool was used exclusively to support literature synthesis, text revision, and structural organization. All scientific content, methodological decisions, data interpretation, and intellectual contributions remain the sole responsibility of the human authors. This disclosure follows the ethical guidelines of IEEE for AI-assisted academic writing.

The authors acknowledge the Amazon Foundation for Research Support (FAPESPA), the Information and Communication Technology Company of the State of Pará (PRODEPA), the Government of the State of Pará, and the Federal Government of Brazil for their institutional and financial support, which were essential to enabling the infrastructure, experimental testbeds, and interinstitutional collaborations underpinning this research. Special thanks are extended to the spinoff SEC365 and to the Laboratory of Informatics and Computing of the Amazon (LICA/UFGA) and Smart and Sustainable Cities Laboratory (LaCIS/UFGA), whose teams played a decisive role in the development, validation, and technical implementation of this work. The authors also acknowledge the High-Performance Computing and Artificial Intelligence Center (CCAD-IA/UFGA) and the National Education and Research Network (RNP) for providing computing resources and technical assistance during the experimental phases. This work was further supported by the National Institute of Science and Technology in Artificial Intelligence Applied to Smart and Sustainable Cities in the Brazilian Amazon (INCT iAmazônia).

REFERENCES

- [1] P. Rajpurkar, E. Chen, O. Banerjee, and E. J. Topol, "AI in health and medicine," *Nature Medicine*, vol. 28, pp. 31–38, 2022.
- [2] E. J. Topol, "High-performance medicine: the convergence of human and artificial intelligence," *Nature Medicine*, vol. 25, pp. 44–56, 2019.
- [3] A. Esteva, A. Robicquet, B. Ramsundar, V. Kuleshov, M. DePristo, K. Chou, C. Cui, G. Corrado, S. Thrun, and J. Dean, "A guide to deep learning in healthcare," *Nature Medicine*, vol. 25, pp. 24–29, 2019.
- [4] R. Miotto, F. Wang, S. Wang, X. Jiang, and J. T. Dudley, "Deep learning for healthcare: review, opportunities and challenges," *Briefings in Bioinformatics*, vol. 19, no. 6, pp. 1236–1246, 2018.
- [5] M. E. H. Chowdhury, T. Rahman, A. Khandakar, R. Mazhar, and et al., "Can AI help in screening viral and COVID-19 pneumonia?" *IEEE Access*, vol. 8, pp. 132 665–132 676, 2020.
- [6] V. Natarajan, A. Cossette-Léger, and et al., "Towards responsible development of generative AI for health," in *Nature Medicine*, 2024.
- [7] W. N. Price and I. G. Cohen, "Privacy in the age of medical big data," *Nature Medicine*, vol. 25, pp. 37–43, 2019.
- [8] I. Y. Chen, P. Szolovits, and M. Ghassemi, "Can AI help reduce disparities in general medical and mental health care?" *AMA Journal of Ethics*, vol. 21, no. 2, pp. 167–179, 2019.
- [9] G. Kaissis, M. R. Makowski, D. Rueckert, and R. F. Braren, "End-to-end privacy preserving deep learning on multi-institutional medical imaging," *Nature Machine Intelligence*, vol. 3, pp. 473–484, 2021.
- [10] P. F. Edemekong, P. Annamaraju, and M. J. Haydel, "HIPAA compliance and electronic health records," *StatPearls*, 2023.
- [11] P. Voigt and A. von dem Bussche, "The EU general data protection regulation (GDPR): A practical guide," *Springer*, 2017.
- [12] C. Gentry, "A fully homomorphic encryption scheme," *PhD Thesis, Stanford University*, 2009.
- [13] R. Gilad-Bachrach, N. Dowlin, K. Laine, K. Lauter, M. Naehrig, and J. Wernsing, "CryptoNets: Applying neural networks to encrypted data with high throughput and accuracy," in *Proceedings of ICML*, 2016.
- [14] Q. Lou and L. Jiang, "HEMET: A homomorphic-encryption-friendly privacy-preserving mobile neural network architecture," *Proceedings of ICML*, 2021.
- [15] J.-W. Lee, H. Kang, Y. Lee, W. Choi, J. Eom, M. Deryabin, E. Lee, J. Lee, D. Yoo, Y.-S. Kim, and J.-S. No, "Privacy-preserving machine learning with fully homomorphic encryption for deep neural network," *IEEE Access*, vol. 10, pp. 8460–8473, 2022.
- [16] A. E. W. Johnson, T. J. Pollard, L. Shen, L.-w. H. Lehman, M. Feng, M. Ghassemi, B. Moody, P. Szolovits, L. A. Celi, and R. G. Mark, "MIMIC-III, a freely accessible critical care database," *Scientific Data*, vol. 3, p. 160035, 2016.
- [17] H. B. Mann and D. R. Whitney, "On a test of whether one of two random variables is stochastically larger than the other," *The Annals of Mathematical Statistics*, vol. 18, no. 1, pp. 50–60, 1947.
- [18] J. H. Cheon, A. Kim, M. Kim, and Y. Song, "Homomorphic encryption for arithmetic of approximate numbers," in *Advances in Cryptology – ASIACRYPT 2017*, 2017.
- [19] J. Fan and F. Vercauteren, "Somewhat practical fully homomorphic encryption," in *IACR ePrint Archive*, 2012.
- [20] C. Boura, N. Gama, M. Georgieva, and D. Jetchev, "CHIMERA: Combining ring-LWE-based fully homomorphic encryption schemes," in *Journal of Mathematical Cryptology*, 2020.
- [21] A. Wood, K. Najarian, and D. Kahrobaei, "Homomorphic encryption for machine learning in medicine and bioinformatics," *ACM Computing Surveys*, vol. 53, no. 4, pp. 1–35, 2020.
- [22] Z. Chen, K. Laine, and R. Player, "Simple encrypted arithmetic library v2.3.0," *Microsoft Research Tech Report*, 2022.
- [23] P. Mohassel and Y. Zhang, "SecureML: A system for scalable privacy-preserving machine learning," in *IEEE Symposium on Security and Privacy (S&P)*, 2017.
- [24] F. Boemer, R. Cammarota, D. Demmler, T. Schneider, and H. Yalame, "MP2ML: A mixed-protocol machine learning framework for private inference," *IACR Cryptol. ePrint Arch.*, 2020.
- [25] W.-j. Lu, Z. Huang, C. Hong, Y. Ma, and H. Qu, "Pegasus: Bridging polynomial and non-polynomial evaluations in homomorphic encryption," *IEEE Symposium on Security and Privacy*, 2021.
- [26] T. Ryffel, A. Trask, M. Dahl, B. Wagner, J. Mancuso, D. Rueckert, and J. Passerat-Palmbach, "A generic framework for privacy preserving deep learning," in *Privacy in Machine Learning Workshop, NeurIPS*, 2018.
- [27] S. Wagh, D. Gupta, and N. Chandran, "FALCON: Honest-majority maliciously secure framework for private deep learning," *Proceedings on Privacy Enhancing Technologies*, vol. 2021, no. 1, pp. 188–208, 2021.
- [28] T. Zhu, D. Ye, W. Wang, W. Zhou, and P. S. Yu, "More than privacy: Applying differential privacy in key areas of artificial intelligence," *IEEE Transactions on Knowledge and Data Engineering*, vol. 34, no. 6, pp. 2824–2843, 2022.
- [29] Q. Zhang, L. Zhu, C. Xu, and R. Li, "A survey on federated learning in healthcare: Challenges and applications," *IEEE Transactions on Industrial Informatics*, vol. 19, no. 2, pp. 1416–1428, 2023.
- [30] S. Sav, A. Pyrgelis, J. R. Troncoso-Pastoriza, D. Froelicher, J.-P. Bossuat, J. S. Sousa, and J.-P. Hubaux, "POSEIDON: Privacy-preserving federated neural network learning," *Proceedings of NDSS*, 2021.
- [31] D. Froelicher, J. R. Troncoso-Pastoriza, A. Pyrgelis, S. Sav, J. S. Sousa, J.-P. Bossuat, and J.-P. Hubaux, "Scalable privacy-preserving distributed learning," in *Proceedings on Privacy Enhancing Technologies*, 2021.
- [32] J. Ma, S.-A. Naas, S. Sigg, and X. Lyu, "Privacy-preserving federated learning based on multi-key homomorphic encryption," *Parallel Computing*, vol. 112, p. 102922, 2022.
- [33] R. Xu, N. Baracaldo, Y. Zhou, A. Anwar, and H. Ludwig, "HybridAlpha: An efficient approach for privacy-preserving federated learning," *ACM Workshop on Artificial Intelligence and Security*, 2019.
- [34] J. Zhou, L. Wu, X. Dong, and F. Kong, "Privacy-preserving federated learning via functional encryption, revisited," *IEEE Transactions on Information Forensics and Security*, vol. 18, pp. 1855–1869, 2023.
- [35] G. Xu, H. Li, S. Liu, K. Yang, and X. Lin, "Verifynet: Secure and verifiable federated learning," *IEEE Transactions on Information Forensics and Security*, vol. 15, pp. 911–926, 2020.
- [36] M. Kim, Y. Song, S. Wang, Y. Xia, and X. Jiang, "Secure logistic regression based on homomorphic encryption: Design and evaluation," *JMIR Medical Informatics*, vol. 6, no. 2, p. e19, 2018.
- [37] A. Vizitiu, C. I. Nită, A. Puiu, C. Suci, and L. M. Itu, "Applying deep neural networks over homomorphic encrypted medical data," *Computational and Mathematical Methods in Medicine*, 2020.

- [38] O. Kocabas and T. Soyata, "Towards privacy-preserving medical image analysis with homomorphic encryption," *arXiv preprint (workshop version at IEEE EMBC 2022)*, 2022.
- [39] J. L. Raisaro, J. Troncoso-Pastoriza, M. Misbach, J. S. Sousa, S. Pradervand, E. Missiaglia, O. Michielin, B. Ford, and J.-P. Hubaux, "MedCo: Enabling secure and privacy-preserving exploration of distributed clinical and genomic data," *IEEE/ACM Transactions on Computational Biology and Bioinformatics*, vol. 16, no. 4, pp. 1328–1341, 2018.
- [40] O. Batchelor, C. Boura, and N. Gama, "Efficient homomorphic evaluation of k-NN classifiers," in *IACR ePrint*, 2024.
- [41] J. W. Bos, K. Lauter, J. Loftus, and M. Naehrig, "Improved security for a ring-based fully homomorphic encryption scheme," in *Cryptography and Coding – IMACC 2013*, 2013, pp. 45–64.
- [42] R. Ran, S. Wei, J. Wang, Q. Chen, and L. Yang, "Cryptographic inference via homomorphic encryption," *IEEE Transactions on Dependable and Secure Computing*, vol. 20, no. 4, pp. 3288–3302, 2023.
- [43] M. Ali, R. Dharmotharan, E. Khan, and F. Al-Turjman, "Secure medical data transmission based on blockchain and homomorphic encryption," *IEEE Transactions on Consumer Electronics*, vol. 69, no. 4, pp. 1054–1065, 2023.
- [44] M. R. Albrecht, R. Player, and S. Scott, "On the concrete hardness of learning with errors," *Journal of Mathematical Cryptology*, vol. 9, no. 3, pp. 169–203, 2015.
- [45] C. Peikert, "A decade of lattice cryptography," *Foundations and Trends in Theoretical Computer Science*, vol. 10, no. 4, pp. 283–424, 2016.
- [46] National Institute of Standards and Technology, "Post-quantum cryptography standards: FIPS 203, 204, 205," *NIST Federal Information Processing Standards*, 2024.
- [47] J. Bos, C. Costello, L. Ducas, I. Mironov, M. Naehrig, V. Nikolaenko, A. Raghunathan, and D. Stebila, "FRODO: Take off the ring! practical, quantum-secure key exchange from LWE," *ACM CCS*, 2016.
- [48] Microsoft SEAL Team, "Microsoft SEAL (release 4.1)," 2024.
- [49] H. Harutyunyan, H. Khachatrian, D. C. Kale, G. Ver Steeg, and A. Galstyan, "Multitask learning and benchmarking with clinical time series data," *Scientific Data*, vol. 6, p. 96, 2019.
- [50] C. Guo, G. Pleiss, Y. Sun, and K. Q. Weinberger, "On calibration of modern neural networks," in *Proceedings of the 34th International Conference on Machine Learning (ICML)*, 2017, pp. 1321–1330.
- [51] S. van Buuren and K. Groothuis-Oudshoorn, "mice: Multivariate imputation by chained equations in R," *Journal of Statistical Software*, vol. 45, no. 3, pp. 1–67, 2011.
- [52] M. Abadi, A. Chu, I. Goodfellow, H. B. McMahan, I. Mironov, K. Talwar, and L. Zhang, "Deep learning with differential privacy," in *ACM CCS*, 2016.
- [53] C. Dwork, F. McSherry, K. Nissim, and A. Smith, "Calibrating noise to sensitivity in private data analysis," in *Theory of Cryptography Conference*, 2006.
- [54] CryptoLab, "HEaaN: Homomorphic encryption for arithmetic of approximate numbers library," 2024.

Allan Douglas Costa received his M.Sc. and Ph.D. degrees in Computer Science. He is currently a Professor at the Federal Rural University of the Amazon (UFRA), Institute of Computing and Information and Communication Technology (ICIBE), Belém, Pará, Brazil. His research interests include cybersecurity, artificial intelligence, distributed systems, and post-quantum cryptography. He is a member of IEEE. Contact: allan.costa@ufra.edu.br | ORCID: 0000-0002-7068-8889.